

3. Návrh OS a jeho bezpečnost: důvody náročnosti implementace OS, principy jeho vývoje, zabezpečení, typy útoků a prevence, ochrana systému, dat, uživatelů, procesů.

Cíle návrhu:

- Hlavní společné cíle
 - definovat abstrakce
 - poskytnout základní operace
 - zajistit izolaci
 - spravovat HW
- Uživatelský pohled:
 - snadno použitelný
 - snadno naučitelný
 - spolehlivý
 - rychlý
 - bezpečný
- System. hledisko:
 - snadná implementace
 - snadná údržba
 - přizpůsobivost
 - spolehlivost
 - bezchybnost
 - atd...

Důvody náročnosti implementace OS:

1. rozsáhlost, komplexnost
2. konkurence – procesy spolu soupeří o systémové prostředky
3. ochrana – implementaci izolace procesů a oprávnění na souborových systémech
4. sdílení dat a prostředků - izolace nesmí být absolutní > selektivní sdílení dat mezi uživateli
5. životnost - kompatibilita s novým HW i SW, snadná aktualizace ovladačů
6. obecnost použití - OS musí být dobře škálovatelný (vývojář neví co uživatel bude dělat a jaké programy vyvinou programátoři)
7. přenositelnost - provozování i na jiném než původním HW
8. zpětná kompatibilita - kompatibilita s předchozími verzemi OS, kvůli starším aplikacím

Principy vývoje OS:

- jednoduchost, úplnost (OS by měl dělat to co má a nic navíc = jasné chování)
- každá část (funkce, vlastnost nebo systémové volání) by měla dělat jednu věc a tu dobře a správně
- pokud je vlastnost “možná” potřeba, je lepší ji dát do knihovny, nikoli do jádra

Bezpečnost OS:

Hlavní cíle bezpečnosti jsou:

- Zajištění důvěrnosti dat
- Integrita dat
- Dostupnost systému a dat

Typy útoků:

Útoky zvenčí – většinou po síti

Útoky zevnitř – od uživatelů, pro které je systém určen.

Typy útoků na systém:

- trojské koně – nevině vypadající programy, které mají „funkci“ navíc (malware)
- login spoofing – imitace přihlašovací obrazovky
- viry, červy
- zadní vrátka – “trap door”; vložená metoda přístupu navíc, např. aktivuje se při speciální kombinaci vstupních dat
- logické/časované bomby – po určité době nebo za určitých podmínek se spustí škodlivý kód
- buffer / stack overflow – neošetření vstupů
- skenování portů – “port scanning”
- DoS (Denial of Service) – zahlcení serveru množstvím požadavků, takže se služba zastaví nebo alespoň velmi zpomalí

Prevence:

Při ochraně dat je třeba promyslet cenu dat a podle toho navrhnout (cenově) vhodné zabezpečení.

- autentifikace (též autentizace) – ověření identity uživatele. Identitu lze ověřit mnoha způsoby. Typicky se přiděluje uživateli přihlašovací jméno a heslo.
- autorizaci – ověření oprávnění, tedy co smí uživatel se systémem dělat a která data bude mít přístupná. Mezi různé způsoby zajištění patří:
 - domény ochrany – stanovení domén a práv,
 - ACL (Access Control List) – stanovení seznamu práv na objekty pro jednotlivé uživatele a jejich skupiny
 - capability (C-list) – stanovení práv procesům
 - firewally a komunikační filtry